

业务应用API接入规范 — TikTok 内容中台

版本：v1.0 · 日期：2026-05-15 · 编制：IT部 · 适用范围：TikTok 内容中台（Manus）

1 背景

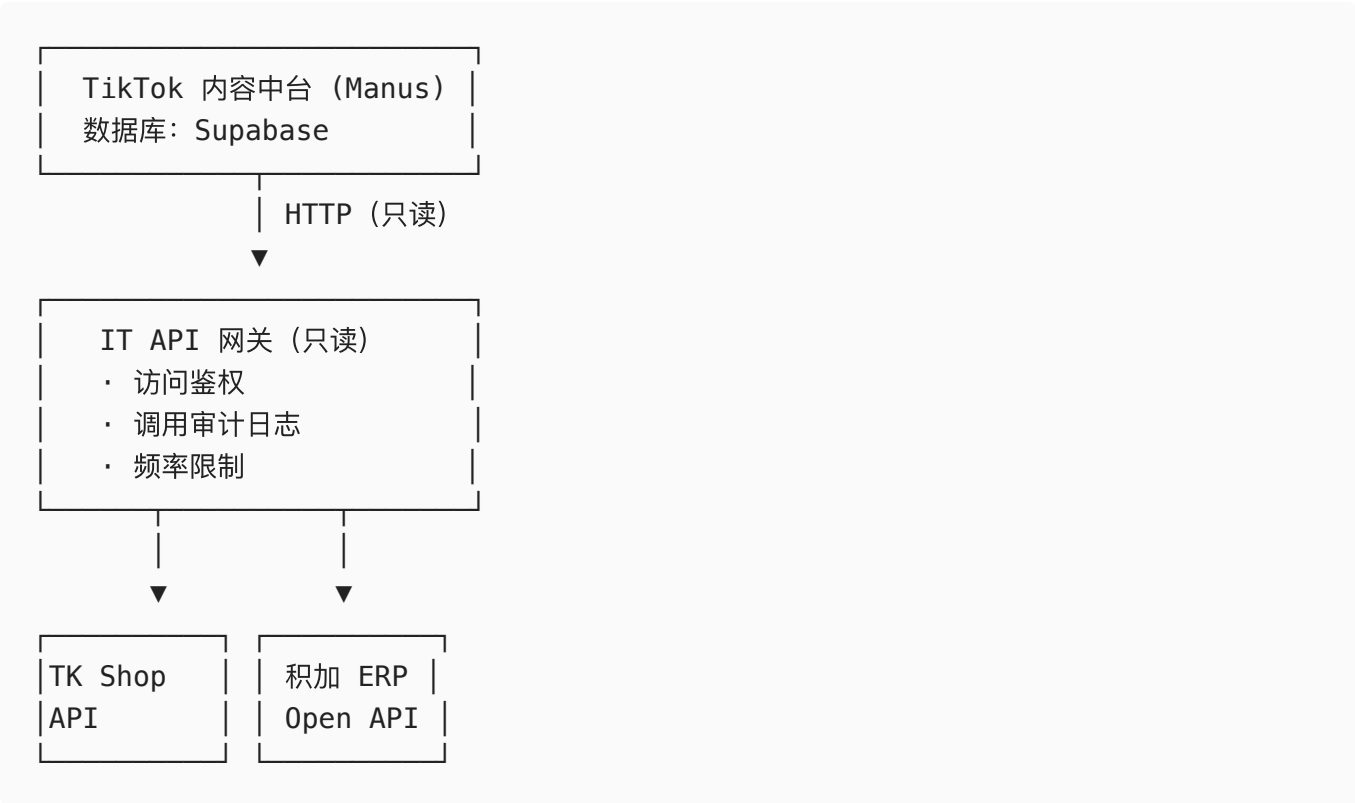
业务部门在 Manus 平台上搭建了「TikTok 内容中台」应用（[线上地址](#)），用于统一管理 TikTok Shop 和 Shopify 跨平台商品信息、定价策略及内容运营。

该应用的商品数据分为三类来源：

- **A类**：TikTok Shop API 自动同步
- **B类**：积加 ERP API 自动同步
- **C类**：运营人员手工维护

本规范定义 IT 部为该应用提供 A 类和 B 类数据 API 接入的技术方案、安全要求和职责边界。

2 接入架构



核心原则：业务应用不直接持有 TK Shop / 积加的 API 凭证，统一经 IT 网关访问。

3 API 接口清单

3.1 TikTok Shop 接口

接口1：获取商品详情（GET PRODUCT）

项目	说明
上游 API	TikTok Shop GET PRODUCT
IT 端点	GET /api/v1/tk/product/{pid}
认证方式	IT 网关 Token（Bearer）
调用频率	建议 ≥5 分钟/次
IT 内部状态	待开发

提供的字段（对应文档  A 类）：

字段	TK API 路径	用途
PID	products[].id	商品唯一标识，主键
主图	main_images[].urls[]	商品主图 URL
商品状态	products[].status	在售/下架/草稿等
TK 审核状态	products[].audit.status	审核流程状态
产品品牌	brand.name	品牌名称
更新日期	products[].update_time	最后更新时间戳
站点	products[].sales_regions[]	销售站点代码（US/UK/AU）

接口2：搜索商品列表（Search Products）

项目	说明
上游 API	TikTok Shop Search Products
IT 端点	GET /api/v1/tk/products?page_token={token}
认证方式	IT 网关 Token（Bearer）
调用频率	建议 ≥5 分钟/次
IT 内部状态	待开发（需对接 TK Search Products API）

提供的字段：同接口1，额外支持分页（next_page_token）和按状态筛选。

3.2 积加 ERP 接口

接口3：SKU 关联多平台 MSKU

项目	说明
上游 API	积加开放平台 — SKU 关联多平台接口
IT 端点	GET /api/v1/gerpgo/sku-msku?pid={pid}
认证方式	IT 网关 Token (Bearer)
IT 内部状态	已有对接基础，具体接口需开发

提供的字段（对应文档 🟡 B 类）：

字段	用途
所属店铺	商品所属店铺名称，由积加 ERP 自动关联

接口4：查询产品详情

项目	说明
上游 API	积加开放平台 — 查询产品详情接口
IT 端点	GET /api/v1/gerpgo/product/{spu}
认证方式	IT 网关 Token (Bearer)
IT 内部状态	已有对接基础，具体接口需开发

提供的字段：

字段	用途
产品主 SPU	积加 ERP 内的 SPU 编号
产品品类	三级品类，格式：一级 > 二级 > 三级

接口5：查询父产品信息（SPU 级）

项目	说明
上游 API	积加开放平台 — 查询父产品信息接口
IT 端点	GET /api/v1/gerpgo/spu/{spu}

项目	说明
认证方式	IT 网关 Token (Bearer)
IT 内部状态	已有对接基础，具体接口需开发

提供的字段：

字段	用途
产品中文名	SPU 级别的内部中文商品名称

3.3 统一响应格式

所有 IT 网关接口遵循统一 JSON 格式：

成功响应：

```
{
  "code": 0,
  "message": "success",
  "data": { ... },
  "request_id": "req_abc123"
}
```

失败响应：

```
{
  "code": 40001,
  "message": "Token expired",
  "data": null,
  "request_id": "req_abc123"
}
```

常见错误码：

错误码	含义	业务侧处理
40001	Token 无效或过期	联系IT轮换Token
42901	请求频率超限	降低调用频率，5分钟后重试
50001	上游API异常	等待恢复，IT会主动排查
50002	数据字段映射异常	检查字段映射，联系IT确认

4 安全规范

4.1 红线

- 只读访问：IT 网关仅暴露只读接口，不提供任何写入/修改能力
- 凭证隔离：业务应用不持有上游 API（TK Shop / 积加）的原始凭证
- 数据不回流：业务应用产生的数据不入库到公司核心数据库
- 传输加密：所有 API 调用必须走 HTTPS

4.2 访问控制

措施	说明
网关 Token	IT 分配专用 Token，绑定来源 IP 或域名白名单
频率限制	单 Token 每分钟上限 20 次请求
审计日志	记录每次调用的端点、参数、时间戳、响应状态
Token 轮换	每 90 天轮换一次，IT 侧发起

4.3 数据脱敏

IT 网关在返回数据前过滤以下字段：

- 积加内部成本价、采购价等财务字段
- 其他店铺的非公开运营数据
- TK API 返回中非本店铺的数据

5 实施计划

阶段	事项	负责人	工期	交付物
Phase 1	API 端点开发	赖武法 + 龚宏飞	3 个工作日	5 个只读 API 端点 + Swagger 文档
Phase 2	联调测试	赖武法 + 李思唯	1 天	联调通过确认
Phase 3	规范签署	唐耀星	半天	双方确认的接入规范
合计			1 周内	

Phase 1 细项

序号	任务	优先级	说明
1	封装 TK Search PRODUCT 为只读 API	P0	复用已有对接逻辑，加网关鉴权层
2	开发 TK GET Products 对接	P0	新对接，复用 TK 认证 pipeline
3	封装积加 SKU 关联 MSKU 接口	P0	确认积加开放平台具体端点
4	封装积加产品详情 + SPU 信息接口	P1	两个接口可合并开发
5	统一网关鉴权 + 审计日志 + 频率限制	P0	所有接口共用

6 职责边界

职责	IT 部	业务部门
API 端点开发与维护	✓	
上游 API 凭证管理	✓	
API 网关可用性监控	✓	
上游 API 变更适配	✓	
Manus 应用开发与维护		✓
Supabase 或 Manus 数据库管理		✓
C 类手工字段的数据质量		✓
数据同步调度（Manus 端定时任务）		✓
字段映射准确性验证	双方共同	双方共同

IT 不负责 Manus 应用的功能开发、Bug 修复和日常运维。IT 仅提供数据接口层面的支撑。

关于应用托管

IT 9人团队需集中精力维护核心业务系统（ERP、金蝶、数据看板等），无法为每个业务自助应用分配开发和运维资源。

IT 为所有业务自助应用提供统一支持：

- **数据接口**：通过 IT API 网关提供只读数据接口（本文档定义的模式）
- **数据平台**：提供 Supabase 共享数据层，按规范接入即可使用
- **技术指导**：数据结构设计、API 对接方案的建议和评审

应用本身的开发、部署、维护和运营由业务部门自行负责。

7 费用

项目	费用
TK Shop API	免费（自有店铺数据）
积加 API	已有账号，无额外费用
IT API 网关	使用现有服务器，无额外成本
月度总计	0 元

8 变更流程

当业务部门需要新增 API 接口或调整字段时：

- 1. 业务负责人提交需求说明（包含所需字段、数据来源、期望更新频率）
- 2. IT 评估可行性和工作量（1 个工作日内回复）
- 3. 排入迭代计划，按优先级开发
- 4. 联调测试通过后上线

附录A：名词解释

术语	说明
PID	TikTok Shop 商品唯一标识
SPU	标准产品单元，一组相同属性的商品集合
MSKU	多平台 SKU，同一商品在不同平台的库存单位映射
Supabase	Manus 应用使用的 PostgreSQL 云数据库
Manus	业务部门使用的 AI 低代码开发平台
RLS	Row Level Security，PostgreSQL 行级安全策略，控制不同用户/应用可访问的数据行
Schema	PostgreSQL 中的命名空间，用于在同一实例内隔离不同应用的数据对象

附录B：Supabase 使用规范

B.1 定位

Supabase 作为「业务自助应用」的统一数据平台，在三层数据架构中承担第二层角色：

第一层（IT 管控）	→ 核心ERP（积加/金蝶）、内部API网关、公司主数据库
第二层（Supabase）	→ 业务应用共享的数据层，存储API同步数据和业务手工数据
第三层（业务自助）	→ Manus/低代码平台，应用层

Supabase 不是公司核心数据库的替代品。 财务数据、成本价、采购价等敏感数据保留在金蝶和 ERP 内部系统，不进 Supabase。

B.2 适用场景

✔ 适合	✘ 不适合
业务自建应用的数据存储（内容中台、补货表格、寄样管理等）	财务敏感数据（成本价、采购价、利润核算）
IT API 网关的数据缓冲层（API 同步数据落库，减少重复调用）	高并发交易写入场景
跨应用数据共享（商品/店铺基础数据多应用复用）	需要与 ERP 深度双向同步的数据
新项目原型验证（快速建表出接口，验证通过后再决定是否接入核心系统）	涉及资金流转、合同审批的正式业务流程

B.3 使用规则

规则	说明
统一实例	所有业务应用共用一个 Supabase 实例，各自数据互相隔离
IT 管权限	IT 持有管理员账号，负责建表、分配访问密钥、管理权限
数据分级	每张表标注数据级别（公开/内部/受限/禁止），详见下表
敏感数据禁入	采购成本、利润率、供应商价格等财务数据不允许进入 Supabase

数据分级（建表时标注）：

级别	说明	示例
公开	可对外展示	商品标题、主图、品牌、品类
内部	仅公司内部使用	运营负责人、佣金比例
受限	商业敏感信息	直播间秒杀价、广告佣金
禁止	不可进入 Supabase	采购成本、利润率、供应商价格

B.4 新应用接入流程

当有新的业务应用需要使用 Supabase 时：

1. **业务负责人提交申请：** 应用名称、所需数据表、字段清单、预期数据量
2. **IT 审核：** 确认数据分级和表结构（1 个工作日内）

- 3. **IT 建表并分配密钥**：创建表、配置权限、生成访问密钥
- 4. **业务接入**：获得连接信息和密钥后，在 Manus 中配置使用
- 5. **上线验收**：双方确认字段映射和数据准确性

B.5 Manus 接入 Prompt

业务人员在 Manus 中新建应用或接入 Supabase 数据库时，可直接使用以下 Prompt：

你是一个协助企业业务人员搭建应用的助手。现在需要你帮我在 Manus 中配置 Supabase 数据库连接。

连接信息（由 IT 提供，请替换为实际值）：

- Supabase URL: {IT 提供}
- Supabase Anon Key: {IT 提供}

要求：

- 1. 只使用只读方式连接数据库，不要执行任何写入、更新、删除操作
 - 2. 只访问与当前应用相关的数据表，不访问其他应用的数据表
 - 3. 以下类型的数据禁止出现在应用中：采购成本、利润率、供应商价格
 - 4. 建议使用 Supabase 客户端库（@supabase/supabase-js）进行连接
 - 5. 数据展示时做好空值处理，缺失字段显示为 "-" 而不是空白
 - 6. 如果需要定时同步外部 API 数据，请通过 IT 提供的 API 网关（见接入规范第3节）获取数据，不要直接调用 TikTok Shop 或积加的原始接口
- 请帮我完成数据库连接配置，并测试读取 {具体表名} 表的前 5 条数据来验证连接是否正常。

使用方法： 复制以上 Prompt，替换 {} 中的占位符为 IT 提供的实际值，粘贴到 Manus 对话框即可。

B.6 费用标准

方案	月费	数据库容量	适用阶段
Free Plan	0	500 MB	单应用试点（当前阶段）
Pro Plan	\$25（≈180 元）	8 GB	多应用正式使用
Team Plan	\$75（≈540 元）	8 GB + 协作功能	团队协作场景

当前建议使用 Free Plan 启动 TikTok 内容中台试点，待第二个业务应用接入时评估升级 Pro Plan。

B.7 运维职责

事项	IT 部	业务部门
Supabase 账号、计划、备份管理	✓	
建表、分配访问密钥、权限审核	✓	
密钥生成与定期轮换	✓	
业务数据维护（手工字段填写）		✓
数据同步调度（Manus 端定时任务配置）		✓
应用内视图和报表设计		✓